

Cybersecurity

Abusing Active Directory Certificate Services (AD CS)

Lesson 16.4



Class Objectives

By the end of today's class, you will be able to:

1

Understand the role of Active Directory Certificate Services in a Windows Domain.

2

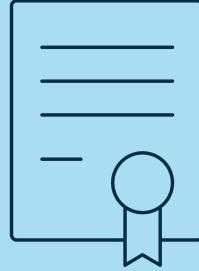
Identify common misconfigurations in AD CS that can be exploited.

3

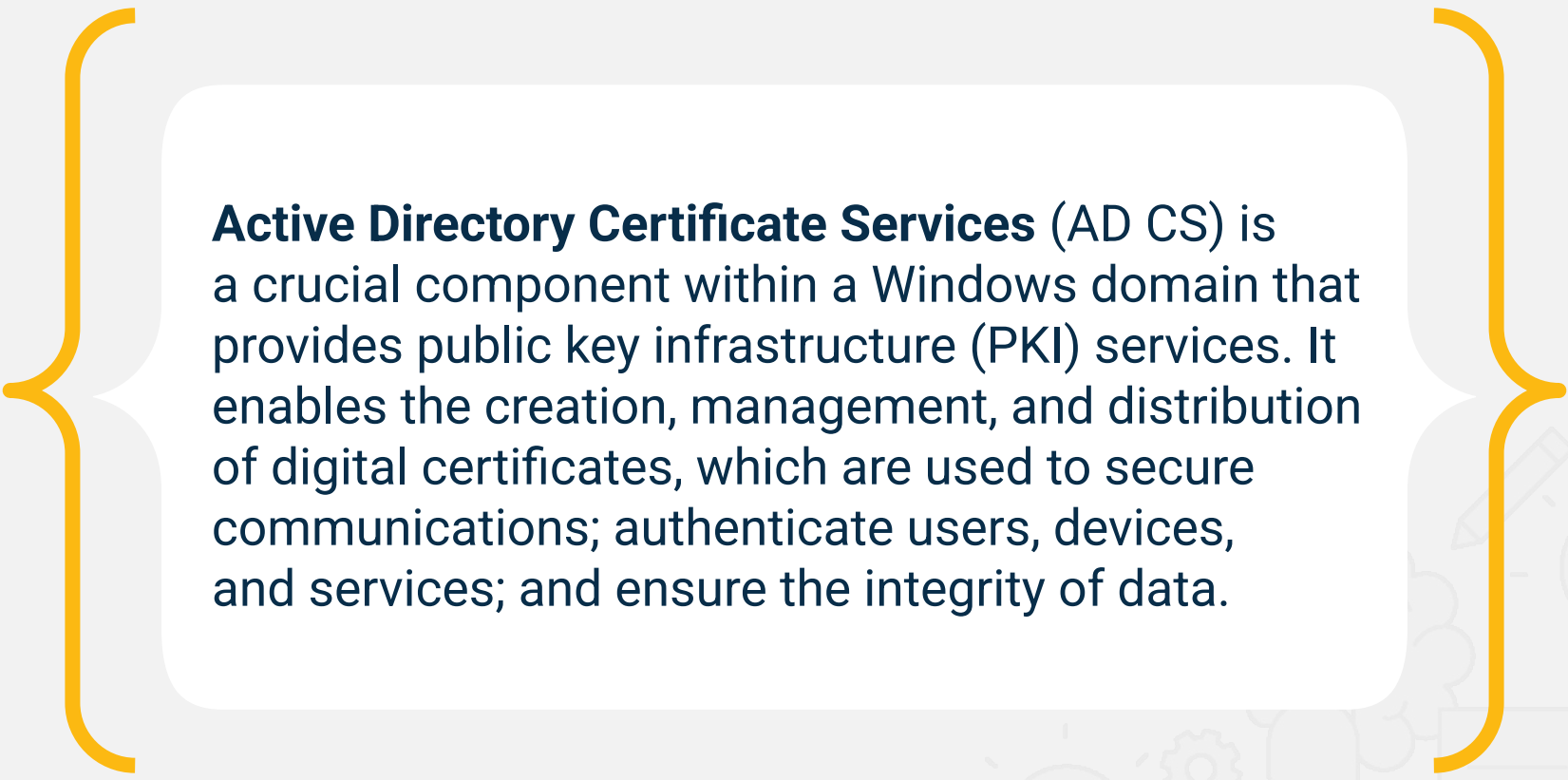
Perform attacks to abuse AD CS, including certificate request forgery and exploitation of misconfigured templates.

4

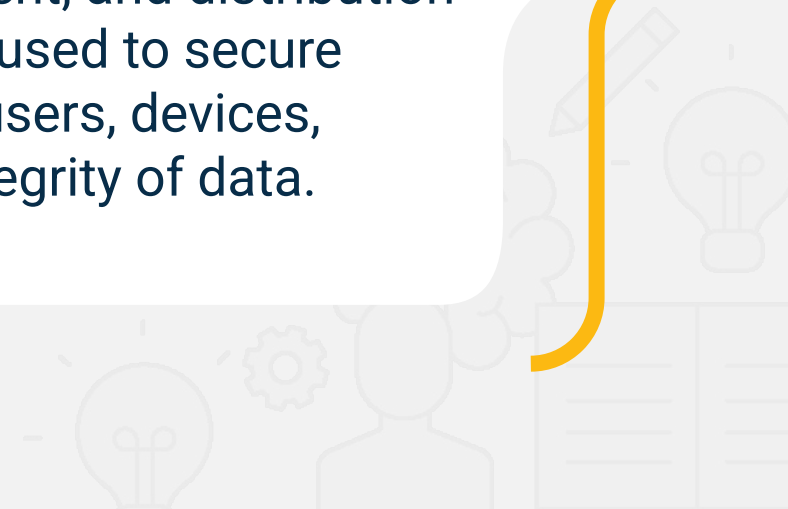
Understand how these techniques can be used for privilege escalation and lateral movement in a domain environment.



Overview of AD Certificate Services



Active Directory Certificate Services (AD CS) is a crucial component within a Windows domain that provides public key infrastructure (PKI) services. It enables the creation, management, and distribution of digital certificates, which are used to secure communications; authenticate users, devices, and services; and ensure the integrity of data.



Role of AD CS in a Windows Domain

01

Issue certificates for various purposes (i.e. encrypting email, SSL or TLS, authentication)

02

Authenticate users or machines within a domain (smart cards or MFA)

03

Secure communications through established channels, including https, S/MIME, and VPNs

04

Enable encryption and digital signatures

Enterprise Environments

Common setups and configurations

01

Enterprise Root and Subordinate CA to issue secure certificates.

02

Certificate Templates to standardize properties and policies of certificates.

03

Autoenrollment to automate enrollment of users and devices without manual intervention.

04

Network Device Enrollment Service (NDES) to secure non-Windows devices.

05

Online Responder to provide real-time certificate status-checking.

AD CS in Enterprise Security

Provides a foundation for trust within the domain by assuring that only authorized users and devices can access sensitive resources.



AD CS Misconfigurations

Improperly configured Certificate Services can lead to significant vulnerabilities

01

Forged Certificates

02

User Impersonation

03

Escalated Privileges



Questions?





Activity

Identifying misconfigurations

In this activity, you will explore a pre-configured AD CS environment to identify potential misconfigurations.

Suggested Time
15 minutes



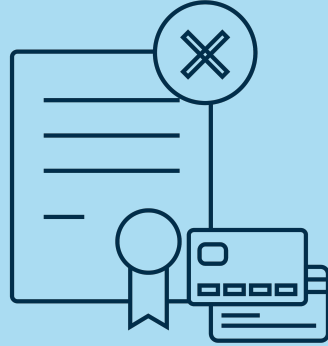


Time's Up!
Let's review



Questions?





Certificate Request Forgery

Certificate Forgery

Misconfigurations that are typically exploited include:

01

Overly permissive
enrollment
permissions

02

Weak cryptographic
settings

03

User-controlled
subject names

Tools to Exploit AD CS

01

Certify

A tool from GhostPack that allows for enumeration of certificate templates, finding vulnerabilities, and crafting certificate requests.



02

Rubeus

A post-exploitation tool that allows for manipulating Kerberos tickets

GhostPack/**Rubeus**

Trying to tame the three-headed dog.



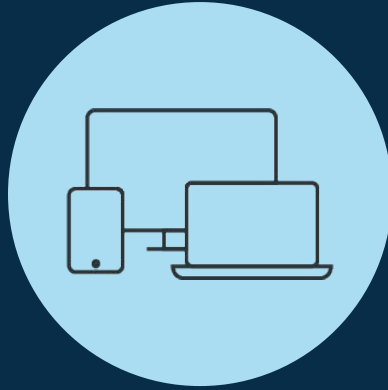
Ak 34
Contributors

19
Issues

4k
Stars

777
Forks





Instructor Demonstration

Certificate request forgery activity

Summary

Critical Analysis of Misconfigurations

Small misconfigurations lead to significant risk of breach.

Defense in Depth

Protecting CS is one part of the story; layered security measures will mitigate damages.

Real-World Implications

Consider advanced persistent threats and how these techniques are used in everyday life.



Questions?





Activity

Exploiting vulnerable templates

In this activity, you will exploit the vulnerabilities you learned about earlier by performing a certificate request forgery against vulnerable templates.

Suggested Time
20 minutes





Time's Up!
Let's review



Questions?



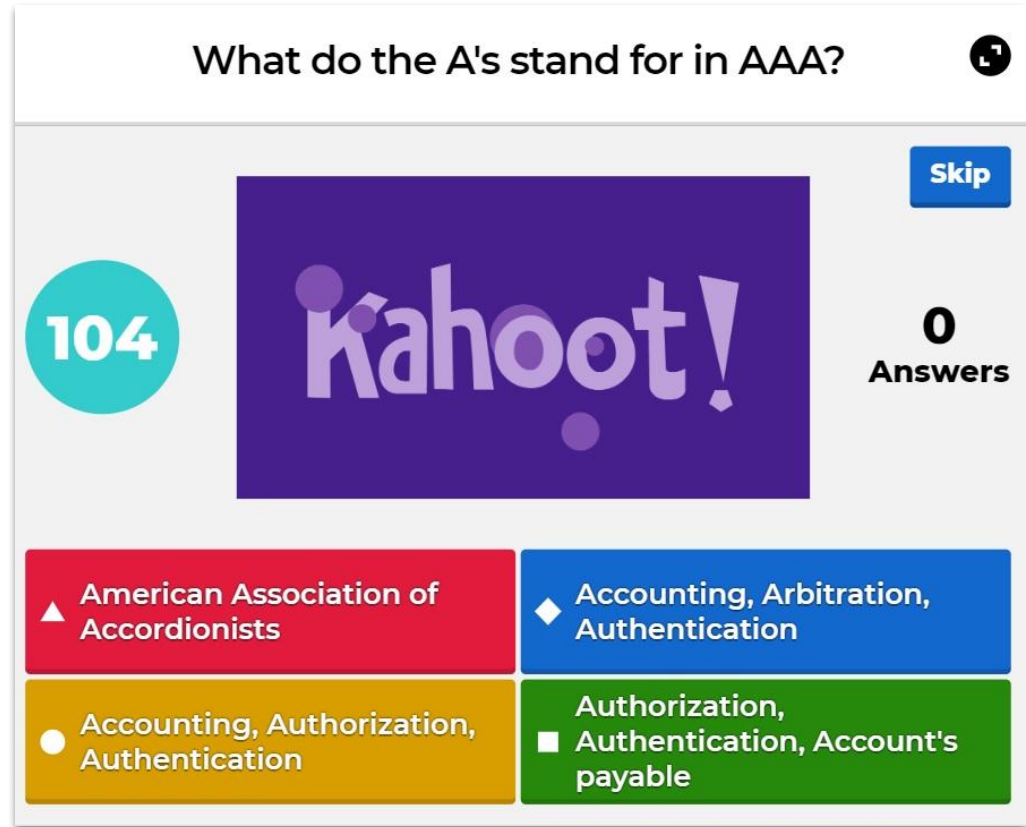
To finish class, we'll review what we've learned
about pen testing with a game of

Kahoot!

What's Kahoot?

Kahoot! is a web-based tool that:

- ! Displays questions and answers to select from in real time.
- ! Keeps track of individual and team scores.
- ! Keeps track of remaining time for each question.





Rules and Guidelines



There are a total of 30 questions.



Points are not deducted for incorrect answers.



You will have two minutes to answer each question.



If you are competing as a team, select a team captain to answer the questions.



Points are awarded for correct answers and for how quickly you answer compared to your classmates.



Note: If your class is currently online, it will be easier if each student competes individually.



Challenge

Start the Kahoot! Pen Testing Week 2 Challenge by accessing the link:

[Kahoot! Pen Testing Week 2 Challenge](#)

Kahoot! Setup

01

Select **Play** if you are logged in. Select **Play as Guest** if you do not have a Kahoot! account.

02

Select **Classic** if you are competing individually and **Team Mode** if you are competing in a group.

03

Leave all the other options as **default**.

04

Follow the instructions on the screen by going to kahoot.it.

05

Enter the unique Kahoot! **code**.

06

Select **Start** to begin.



Time's Up!
Let's review



Thank You